

GRC102 - NEXUSTECH LAB SOLUTION

ZAINAB UMAR SHUAIBU

C11/26/CGRCE/17194

9/19/2026

1. Security Policy Hierarchy & Classification

1. Hierarchy Definition

The table below outlines the four levels of the NexusTech Solutions Information Security Documentation Hierarchy.

Document Level	Purpose	Authority	Mandate Level	Level of Detail
Policy	Defines executive vision, strategic security goals, high-level rules, and compliance commitments aligned with organizational objectives.	Executive Management / CEO	Mandatory	High-level (what must be achieved; non-technical).
Standard	Establishes specific, mandatory technical baselines, configurations, metrics, and technical boundaries required to enforce policy directives.	Information Security Manager / IT Leadership	Mandatory	Medium-to-High (specific parameters, tools, and thresholds).
Guideline	Provides advisory recommendations, operational context, and industry best practices to assist decision-making where flexible application is permissible.	Subject Matter Experts / Security Team	Recommended	Medium (contextual suggestions and best practice examples).
Procedure	Outlines sequential, step-by-step operational workflows and instructions required to execute policy controls	IT Operations / Helpdesk Management	Mandatory	Very High (granular step-by-step instructions).

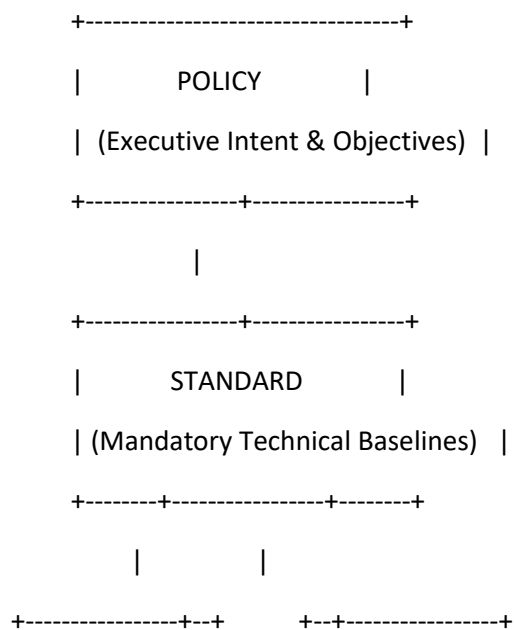
Document Level	Purpose	Authority	Mandate Level	Level of Detail
	consistently across routine tasks.			

2. Statement Categorisation & Justifications

	Statement	Classification	Justification
1	All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.	Policy	It establishes an overarching, mandatory security requirement for remote network access without dictating specific tools or step-by-step technical configurations.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It details sequential, step-by-step instructions for an end user to perform software configuration on a mobile device.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	It offers non-mandatory, advisory coding recommendations to mitigate web vulnerability risks rather than prescribing an absolute technical baseline.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	It expresses high-level governance commitments and strategic intent from executive leadership regarding overall information protection.
5	All corporate laptops must have full-disk encryption enabled using	Standard	It sets a mandatory technical baseline specifying exact cryptographic software

	Statement	Classification	Justification
	BitLocker (Windows) or FileVault (macOS).		configurations required for corporate endpoint security.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	It provides advisory behavioral advice on security hygiene without specifying an enforceable technical control.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	It outlines the exact operational protocol an employee must follow upon encountering an incident.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	It establishes explicit, quantifiable technical rules for credential complexity across organizational systems.

3. Governance Hierarchy Visual Representation



	PROCEDURE			GUIDELINE	
	(Step-by-Step			(Advisory Best	
	Workflows)			Practices)	
+-----+		+-----+			

2. Acceptable Use Policy (AUP)

Document Control

Field	Details
Title	Acceptable Use Policy (AUP)
Document ID	POL-SEC-2026-001
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, Chief Executive Officer
Effective Date	18 September 2026
Review Date	18 September 2027

1. Purpose

NexusTech Solutions designs, builds, and maintains enterprise resource planning (ERP) platforms for clients operating in regulated financial and healthcare environments. The purpose of this policy is to establish clear expectations regarding the acceptable use of NexusTech technology assets, infrastructure, and data. Adherence to this policy safeguards organizational assets, prevents security breaches, ensures compliance with ISO/IEC 27001 and SOC 2 frameworks, and maintains corporate integrity.

2. Scope

This policy applies to all NexusTech personnel, including full-time and part-time employees, contractors, temporary workers, external consultants, and third-party vendors (collectively referred to as "Users").

The scope covers all hardware, software, network systems, cloud databases, client environments, communication channels, and storage media owned, leased, or managed by NexusTech Solutions, whether accessed on-site or remotely.

3. Policy Statements

3.1 Acceptable Use

- Corporate IT assets are provided primarily to perform legitimate business operations, client development, and administrative duties for NexusTech.
- Users must protect credentials, lock unattended workstations (Win+L / Ctrl+Cmd+Q), and use only corporate-approved identity verification mechanisms (including Multi-Factor Authentication).
- All confidential and restricted data, including client financial and health records, must be handled according to NexusTech classification guidelines.

3.2 Prohibited Activities

Users are strictly prohibited from performing the following on any corporate asset or network:

- **Unauthorized Software:** Installing, running, or executing unauthorized applications, administrative tools, unauthorized cloud backup tools, or unapproved software without written clearance from Information Security.
- **Security Interference:** Disabling endpoint security software, altering operating system configurations, attempting network penetration scans, or circumventing system controls without explicit authorization.
- **Shadow IT & Cloud Data Transfer:** Exfiltrating, uploading, or storing NexusTech or client intellectual property, code, or data onto personal cloud accounts, unapproved file-sharing services, or personal devices.
- **Illegal & Inappropriate Content:** Accessing, storing, downloading, or transmitting material that is illegal, defamatory, offensive, or infringing upon intellectual property rights.
- **Credential Sharing:** Sharing user accounts, passwords, MFA tokens, or remote access credentials with any internal or external party.

3.3 Reasonable Personal Use

NexusTech recognizes that occasional, minor personal use of corporate devices (e.g., brief personal browsing or non-work communications during breaks) is acceptable provided that it:

- Does not interfere with job duties or network availability.
- Does not incur additional operational costs for NexusTech.

- Does not violate any prohibited activities outlined in Section 3.2.
- Does not involve commercial activities, political campaigns, or personal business operations.
- Users acknowledge that all activity conducted on company-owned assets remains subject to monitoring and carries no expectation of privacy.

4. Roles & Responsibilities

- **Users (Employees & Contractors):** Responsible for reading, acknowledging, and adhering to this policy; securing assigned equipment; and immediately reporting lost devices or security events.
- **Information Security Team:** Responsible for maintaining, monitoring compliance with, and proposing annual updates to this policy; evaluating exception requests; and investigating potential policy violations.
- **IT Operations / Helpdesk:** Responsible for configuring assets in accordance with baseline security standards and enforcing technical access controls.
- **People & Culture (HR):** Responsible for onboarding attestation workflows, offboarding procedures, and managing formal disciplinary processes resulting from policy breaches.
- **Line Managers:** Responsible for ensuring direct reports complete annual training and maintain security awareness in daily operations.

5. Exceptions

Requests for exceptions to any provision of this policy must be submitted in writing to the Information Security Manager via the official Risk & Exception Request Portal. Exceptions must detail the business justification, technical scope, duration, and compensating controls. Formal approval from both the Information Security Manager and the IT Director is required prior to implementation. Approved exceptions are subject to mandatory re-evaluation every six months.

6. Compliance & Enforcement

Compliance with this policy is mandatory. Non-compliance poses direct financial, legal, and operational risks to NexusTech and its clients. Failure to comply with this policy may result in disciplinary action up to and including:

- Revocation of network access privileges.
- Formal written reprimand placed in the personnel record.
- Immediate termination of employment or contractual engagements.
- Referral to law enforcement authorities where legal statutes are violated.

7. Document Approval

Name	Role	Date	Signature
Marcus Vance	Chief Executive Officer	18 September 2026	<i>M. Vance</i>
Sarah Jenkins	IT Director	18 September 2026	<i>S. Jenkins</i>
Information Security Manager	Author / Maintainer	18 September 2026	<i>[Security Mgr]</i>

3. User Access Request Procedure

Document Metadata

Field	Value
Procedure ID	SOP-IT-2026-004
Title	User Access Request & Provisioning Procedure
Associated Policy	Access Control Policy / Acceptable Use Policy
Owner	IT Helpdesk Manager / InfoSec Manager
Effective Date	18 September 2026

1. Purpose & Scope

This Standard Operating Procedure (SOP) defines the mandatory sequential steps required to request, verify, authorize, provision, and audit user access accounts across NexusTech IT infrastructure, ERP development platforms, and enterprise cloud systems. This procedure applies to all IT Helpdesk technicians and System Administrators handling access requests.

2. Prerequisites

- Active ticketing system access (NexusTech Service Desk Portal).
- Standardized Role-Based Access Control (RBAC) Entitlement Matrix.
- Authorized approver database (Line Managers and Data Owners).

3. Sequential Procedure Steps

Plaintext

[Step 1] Request Intake

|

[Step 2] Identity & Approval Verification

|

[Step 3] Least-Privilege Role Validation

|

[Step 4] Account Creation & Configuration

|

[Step 5] Security Notification & Onboarding

|

[Step 6] Audit Trail & Ticket Resolution

Step 1: Request Intake via Official Portal

1. The requester or hiring manager must log into the **NexusTech Service Desk Portal** and complete the **Standard User Access Request Form**.
2. *Exclusion:* Informal access requests submitted through email, messaging apps, phone calls, or verbal requests must be rejected. Technicians must direct the user to the portal.

Step 2: Verification of Identity and Authorization

1. The Helpdesk technician assigned to the ticket must verify the completeness of the request form, including:

- Full employee name, corporate ID, department, and direct line manager.
 - Specific system(s), environment (e.g., Staging vs. ERP Production), and level of access requested.
- 2. The technician verifies that mandatory written approval from the direct Line Manager is attached to the ticket.
- 3. If access involves restricted client databases or financial/healthcare ERP modules, the technician verifies attached secondary approval from the designated **Data Owner**.
- 4. If approvals are missing, the technician must pause the ticket and issue an automated approval request through the system.

Step 3: Least-Privilege & RBAC Validation

1. The technician compares requested permissions against the **NexusTech Role-Based Access Control (RBAC) Matrix**.
2. If the requested access exceeds the baseline role for the employee's job title, the technician routes the request to the Information Security Team for a Segregation of Duties (SoD) risk check.

Step 4: Account Creation & Provisioning

1. Upon verifying all approvals, the technician creates the user account using the standardized identity convention (first.last@nexustech.com) within Central Identity Management (Active Directory / Entra ID).
2. Assign permissions by adding the account strictly to pre-defined security groups corresponding to approved roles; direct explicit permission assignment to individual files or databases is prohibited.
3. Enforce default security baselines:
 - Enable mandatory Multi-Factor Authentication (MFA).
 - Require temporary password change on initial login.

Step 5: User & Manager Notification

1. The technician sends a secure, automated welcome notice to the user's line manager containing temporary credentials via encrypted email or secure portal token.
2. Direct communication of credentials via unsecured channels is strictly prohibited.

Step 6: Evidence Logging & Ticket Closure

1. The technician attaches the provisioning transaction logs and confirmation screenshots to the Service Desk ticket.
2. System fields recorded must include: Executing Technician ID, Approval Timestamp, Target System, Group Memberships, and Ticket ID.

3. Update ticket status to **Resolved/Closed**.

4. Emergency / Exceptional Access Request Workflow

1. For urgent out-of-hours system restoration or emergency maintenance requiring elevated administrative rights, an **Emergency Access (Break-Glass) Request** must be raised in the Service Desk.
2. On-call IT staff may provision temporary elevated access upon verbal authorization from the IT Director or Security Manager, followed by immediate logged approval in the system within 2 hours.
3. All emergency accounts automatically expire and revoke access after 12 hours.
4. An automated audit report of emergency access is generated and delivered to the Security Manager the following business morning.

5. Record Retention & Audit Trail Requirements

- All ticket records, approval trails, and provisioning logs must be retained within the ticket system for a minimum of 3 years to comply with ISO/IEC 27001 and SOC 2 Type II audit requirements.
- Monthly automated access reconciliation reports must be audited against active HR lists by the IT Helpdesk Lead.

4. Communication and Training Plan

1. Rollout Strategy Overview

To establish effective policy adoption across NexusTech's expanded workforce, a phased communication and training campaign will be executed over a 3-week rollout period. The plan utilizes targeted messaging across distinct organizational groups.

2. Communication Matrix

Target Audience	Key Message	Channel(s)	Campaign Owner	Schedule / Timing	Attestation / Acknowledgment	Success Criteria
All Employees & Contractors	Understanding security expectations,	Town Hall presentation, Email Announcement,	InfoSec Manager & CEO	Week 1 (Days 1–3)	Mandatory digital AUP policy signature via HR portal.	100% completion rate within 14 days;

Target Audience	Key Message	Channel(s)	Campaign Owner	Schedule / Timing	Attestation / Acknowledgment	Success Criteria
	acceptable personal use boundaries, avoiding shadow IT, and protecting client data.	Intranet Banner.				>90% score on post-training quiz.
IT Staff & Helpdesk Technicians	Enforcing formal access workflows, rejecting informal requests, administrative boundaries, and auditing guidelines.	Interactive Technical Workshop, Standard Operating Procedure (SOP) walkthrough.	IT Director & Security Lead	Week 2 (Days 8–10)	Signed SOP compliance agreement & operational checklist.	0% unverified access requests logged in Helpdesk ticket audits.
Management & Data Owners	Roles in access approval, accountability for team compliance, identifying shadow IT, and managing risk.	Executive Briefing session, Management email memo.	InfoSec Manager	Week 1 (Day 5)	Management oversight sign-off sheet.	100% manager completion of quarterly access review sign-offs.

3. Implementation Schedule & Rollout Timeline

- **Week 1 (Launch & Awareness):**
 - Day 1: Official executive email announcement from CEO Marcus Vance launching the new AUP framework.
 - Day 3: All-hands Town Hall meeting introducing the Security Governance framework.
 - Day 5: Distribution of mandatory Learning Module via Learning Management System (LMS).
- **Week 2 (Targeted Technical Training):**
 - Day 8–10: SOP training for Helpdesk personnel and System Administrators.
 - Day 12: Automated email reminders to staff with pending policy acknowledgements.
- **Week 3 (Attestation & Review):**
 - Day 15: Final compliance deadline for AUP digital signature and quiz completion.
 - Day 18: Escalation reporting to department heads for non-compliant employees.

4. Non-Compliance & Escalation Framework

Plaintext

[Day 15] Non-Completion / Breach Identified

|

[Stage 1] Automated System Reminder & Notification to Line Manager (24 hrs)

|

[Stage 2] Line Manager 1-on-1 Session & HR Formal Flag (Day 18)

|

[Stage 3] Access Suspension & Escalation to HR / Security Manager (Day 21)

1. **First Incident / Pending Attestation (Day 15):** Automated email notification sent to user and copied to Line Manager giving 48 hours to complete.
2. **Second Incident / Overdue (Day 18):** Line Manager holds direct follow-up session; People & Culture (HR) flags the record as non-compliant.

3. **Persistent Non-Compliance (Day 21):** Temporary suspension of corporate network access until training/acknowledgement is successfully completed, accompanied by formal HR written notification.

5. Policy Review and Maintenance Memo

MEMORANDUM

TO: Information Security Steering Committee

FROM: Information Security Manager

DATE: 18 September 2026

SUBJECT: Policy Review Memo Cloud Migration & Sensitive Document Exposure Incident

Executive Summary & Trigger Identification

Following our infrastructure expansion over the past year, two critical events require an immediate review and revision of NexusTech's security policy framework. First, the formal migration of our core Enterprise Resource Planning (ERP) databases to Amazon Web Services (AWS) has fundamentally shifted our perimeter from on-premises assets to a hybrid cloud environment. Second, a recent security incident involving an employee uploading sensitive client files to a personal cloud storage account highlighted operational ambiguity regarding unapproved cloud applications. These developments create compliance gaps under ISO/IEC 27001 and SOC 2 standards that must be addressed immediately.

Stakeholder Review Process & Proposed Revisions

Our review process involved risk assessments, log analysis, and consultation with IT Operations, Legal Counsel, and Software Development Leads. To address current operational risks, I propose updating Section 3.2 of the Acceptable Use Policy to explicitly ban unauthorized third-party cloud applications ("Shadow IT") and enforce data loss prevention (DLP) technical controls. Furthermore, we will publish a new **Cloud Data Handling Standard** outlining mandatory encryption and access protocols for AWS environments. These additions clarify employee responsibilities, regulate cloud usage, and provide enforceable guidelines for handling data across cloud systems.

Policy Maintenance Governance & Future Review Triggers

The revised policy documents will be maintained by the Information Security Manager and submitted to CEO Marcus Vance and the Steering Committee for formal approval by October 15, 2026. While formal policies remain subject to mandatory annual reviews, we recommend establishing clear early-review triggers:

- Major architecture changes (such as expanding AWS environments or implementing new SaaS tools).
- Material security incidents or confirmed data leakage events.
- Significant statutory, regulatory, or legal changes affecting client data.

Implementing these continuous review triggers ensures NexusTech maintains a dynamic, responsive security posture that grows alongside our enterprise client portfolio.

References

- **ISO/IEC 27001:2022.** *Information security, cybersecurity and privacy protection — Information security management systems — Requirements.*
- **ISO/IEC 27002:2022.** *Information security, cybersecurity and privacy protection — Information security controls.*
- **NIST Cybersecurity Framework (CSF) 2.0.** *National Institute of Standards and Technology.*
- **AICPA.** *SOC 2 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy.*